OWASP DEPENDENCY-CHECK

What is OWASP
OWASP Dependency-Check is a security tool that scans an application's third-party dependencies and identifies known vulnerabilities in those dependencies.

For a Java/Maven project, dependencies are mainly defined in:
pom.xml

Why do we need Dependency-Check?
Our own application code may be written correctly, but we normally don't write everything from scratch.
We use libraries such as:

1. Spring Boot
2. Jackson
3. Tomcat
4. Spring Framework
5. etc.

1. These are third-party components.
2. A vulnerability may exist inside one of those libraries.
3. Therefore, we scan dependencies before deployment.

Real-Life Example

Imagine you are building a house.
Your Code = House

You purchase different components:
Door = Third-party component
Windows = Third-party component
Lock = Third-party component

The house itself may be constructed properly.

1. But suppose the lock has a known security defect.
2. The problem may not be with the construction of your house; the problem is with a component you purchased.

SIMILARLY
Application
↓
Uses third-party library
↓

Library has known vulnerability
↓
Application has dependency security risk

OWASP Dependency-Check helps identify that problem.

OWASP DEPENDENCY-CHECK INSTALLATION

1.Install Jenkins plugin

1. (OWASP Dependency-Check)

2. Configure Dependency-Check Tool

1. Manage Jenkins
2. Tools
3. Dependency-Check installations
4. Name: owasp
5. Install automatically

3. NVD API Key

1. OWASP Dependency-Check uses vulnerability information from the NVD (National Vulnerability Database).
2. NVD contains information about known software vulnerabilities and CVEs.
3. You can request an NVD API key from:

4.GENERATE NVD API KEY

1. Request API key (https://nvd.nist.gov/developers/request-an-api-key)
2. generate the keys

5.ADD CREDENTIALS IN JENKINS

1. manage jenkins
2. click on credentials
3. Kind: Secret text
4. ID: nvd-api-key
5. Secret: <your NVD API key>

ADVANCED / SECURE CONFIGURATION

```
stage('OWASP Dependency Check') {
   steps {
      dir('backend') {
         withCredentials([
            string(
               credentialsId: 'nvd-api-key',
               variable: 'NVD_API_KEY'
```

```
            )
        ]) {
            sh '''
                mvn org.owasp:dependency-check-maven:check \
                -DnvdApiKeyEnvironmentVariable=NVD_API_KEY
            '''
        }
    }
  }
}
```


